HIPAA & HITRUST Endpoint Compliance & Vulnerability Remediation (Intune + Defender) — Government (GCC High)

Implementation Solution Guide

Version 1.0.0 · 2026-07-01

Contents

Executive Summary — HIPAA & HITRUST Endpoint Compliance & Vulnerability Remediation (Intune + Defender) — Government (GCC High) 5

The problem . . . 5

The solution . . . 5

What is included . . . 5

Important boundary . . . 6

Business value . . . 6

Audience . . . 6

1. Solution Overview — HIPAA & HITRUST Endpoint Compliance & Vulnerability Remediation (Intune + Defender) — Government (GCC High) 6

Description . . . 7

Why this matters . . . 7

The portals you will use (GCC High — memorize these) . . . 7

Commercial vs GCC High — what's different . . . 8

Scope . . . 9

Objects this solution creates (named, and reused across the docs) . . . 10

The standard deployment model . . . 10

Outcomes . . . 11

Audience . . . 11

2. Requirements — HIPAA & HITRUST Endpoint Compliance & Vulnerability Remediation (Intune + Defender) — Government (GCC High) 11

R1 — GCC High tenant and Intune (government cloud) MDM authority . . . 11

R2 — US Government licensing (Intune + Entra ID P1/P2 + Defender for Endpoint P2) . . . 12

R3 — Defender for Endpoint (GCC High) onboarding of clinical endpoints . . . 12

R4 — Administrative roles with least privilege (in the Gov portals) . . . 13

R5 — The clinical endpoint group `HIPAA – Clinical Endpoints` . . . 13

R6 — BitLocker-capable devices (TPM) + Intune disk-encryption policy availability . . . 14

R7 — Patch / update currency via **Update rings** (not update *policies* on GCC High) . . . 14

R8 — Conditional Access readiness (break-glass + report-only) in Gov Entra . . . 14

R9 — Control mapping document and evidence ownership . . . 15

R10 — Named control owner / accountable role . . . 15

R11 — Evidence store / repository (sovereign) . . . 15

R12 — Change control and exception process . . . 16

3. Implementation — HIPAA & HITRUST Endpoint Compliance & Vulnerability Remediation (Intune + Defender) — Government (GCC High) 16

Phase 1 — Assess: map controls to enforceable settings . . . 17

Phase 2 — Configure: compliance policy and configuration baselines . . . 18
Phase 3 — Gate: Conditional Access on compliance (Gov Entra) . . . 21
Phase 4 — Remediate: Defender Vulnerability Management workflow (Gov Defender portal) . . . 22
Phase 5 — Evidence / Report: produce audit-ready output (from US Gov Graph) . . . 23
Phase 6 — Operate: run the control set over time . . . 24
5. Testing & Validation — HIPAA & HITRUST Endpoint Compliance & Vulnerability Remediation (Intune + Defender) — Government (GCC High) 24
Gate 0 — You are on the GCC High cloud (do this first) . . . 24
Gate 1 — Tenant readiness (Assess/Configure prerequisites) . . . 25
Gate 2 — Devices evaluate Compliant . . . 25
Gate 3 — Conditional Access blocks non-compliant devices . . . 25
Gate 4 — Key safeguards enforced . . . 25
Gate 5 — TVM exposure reduced . . . 26
Gate 6 — Evidence produced and retained (sovereign) . . . 26
Regression / ongoing validation . . . 26
6. Troubleshooting — HIPAA & HITRUST Endpoint Compliance & Vulnerability Remediation (Intune + Defender) — Government (GCC High) 27
F. GCC High wrong-cloud and endpoint issues (check this first) . . . 27
Compliance evaluation . . . 28
BitLocker / encryption . . . 29
Automatic lock / antivirus / firewall . . . 29
Conditional Access (the gate) . . . 30
Defender Vulnerability Management . . . 30
Patch / updates (GCC High specifics) . . . 31
Evidence / reporting . . . 31
Discovery / drift . . . 31
7. Best Practices — HIPAA & HITRUST Endpoint Compliance & Vulnerability Remediation (Intune + Defender) — Government (GCC High) 32
Sovereign-cloud hygiene (GCC High first principles) . . . 32
Naming and traceability . . . 32
Compliance policy design . . . 33
Conditional Access (the gate) . . . 33
Vulnerability management (Defender TVM on GCC High) . . . 33
Evidence and audit readiness . . . 34
Operations and change control . . . 34
Least privilege and identity hygiene . . . 34
8. Deliverables Summary — HIPAA & HITRUST Endpoint Compliance & Vulnerability Remediation (Intune + Defender) — Government (GCC High) 35

Documentation 35
Scripts (PowerShell, Microsoft Graph — US Gov `-Environment USGov`) 36
Visual asset 37
How the deliverables fit together 37
Appendix A — PowerShell Scripts 38

Executive Summary — HIPAA & HITRUST Endpoint Compliance & Vulnerability Remediation (Intune + Defender) — Government (GCC High)

The problem

Healthcare and government organizations on the **US sovereign cloud (GCC High)** can *write* an endpoint security policy but rarely *enforce* it on every device or *prove* it on demand. Both a HIPAA audit (or an OCR investigation after a breach) and a HITRUST assessment turn on one question: show that the safeguard was configured, applied to the in-scope devices, and operating during the review period. On a GCC High tenant this is *harder to get right* — the admin portals, service endpoints, and Microsoft Graph environment all differ from Commercial, and several Intune and Defender capabilities lag or are absent. A document that points at a `.com` portal, or a script that omits the US Gov environment, silently reaches the wrong cloud and returns nothing — which looks exactly like "no devices, no evidence." A single unencrypted, unlocked, out-of-date, or vulnerable clinical laptop remains the exposure that turns a lost device into a reportable breach.

The solution

This is the **Government (GCC High) edition**. It converts the technical safeguards of the **HIPAA Security Rule** and the control expectations of the **HITRUST CSF** into enforceable, auditable controls on clinical Windows endpoints using **Microsoft Intune** and **Microsoft Defender for Endpoint (Defender Vulnerability Management)** — configured entirely on the `.us` **sovereign portals**, with **US Gov service endpoints** and **US Gov Microsoft Graph** (`-Environment USGov`). It delivers the repeatable phase model — **Assess** → **Configure** → **Gate** → **Remediate** → **Evidence/Report** → **Operate** — with every object named consistently and traceable from control to enforcement to evidence, and with the **Commercial-vs-GCC High parity gaps called out** so a government tenant is configured correctly rather than with Commercial steps that silently fail.

Concretely, it enforces and proves BitLocker encryption, automatic screen lock, Microsoft Defender Antivirus health and signature currency, Windows Firewall, patch currency (via **Update rings** — the GCC-High-correct mechanism, since the newer update *policies* are not yet available in Gov), and account/sign-in controls; blocks non-compliant clinical endpoints from corporate resources via a Conditional Access gate; drives down vulnerability exposure through a governed Defender remediation and exception workflow; and emits dated, audit-ready evidence into a retained, access-controlled **sovereign** repository.

What is included

- A **control-to-policy mapping** tying each in-scope HIPAA/HITRUST safeguard to a named Microsoft object

and an accountable owner.

- Named **Intune compliance policy** and **configuration baselines** that measure and enforce the

endpoint safeguards on GCC High.

- A named **Conditional Access gate** requiring device compliance before access.
- A **Defender Vulnerability Management** remediation workflow with exception handling and exposure-trend

reporting (core + premium DVM are available in GCC High).

- Five **PowerShell tools** connecting to **US Gov Graph** for discovery, per-device validation, evidence

reporting, safe remediation, and scope-group/scope-tag targeting — all read-only by default; change scripts default to `-WhatIf`.

- A **cited GCC High parity reference** mapping every portal, endpoint, licensing SKU, and feature gap.

Important boundary

HIPAA and HITRUST are **frameworks**, not products. This solution provides the **technical enforcement and evidence layer** that supports a compliance program on a sovereign tenant; it does **not** by itself make an organization HIPAA compliant or confer HITRUST certification, which require organizational policy, risk analysis, workforce training, business associate agreements, physical safeguards, and authorized third-party assessment. **Microsoft Purview Compliance Manager** (`compliance.microsoft.us`) is referenced as an optional assessment aid.

Business value

- **Sovereign-correct from day one:** the right `.us` portals, US Gov endpoints, and US Gov Graph — no

silent wrong-cloud failures.

- **Audit readiness:** trace any control to its enforcement and to dated evidence in seconds.
- **Breach-risk reduction:** encrypted, locked, protected, patched endpoints — and a gate that keeps

non-compliant devices out of ePHI.

- **Measurable exposure reduction:** a governed vulnerability workflow with trend evidence over time,

designed around the two DVM functions unavailable in Gov.

- **Repeatable and portable:** a named, documented pattern an internal team or MSP can deploy across

clinical sites on GCC High.

Audience

Healthcare and government IT/security administrators, virtual CISOs and compliance leads, and MSPs delivering managed compliance for regulated sovereign-cloud clients.

1. Solution Overview — HIPAA & HITRUST Endpoint Compliance & Vulnerability Remediation (Intune + Defender) — Government (GCC High)

This is the **Government (GCC High) edition** of the HIPAA & HITRUST Endpoint Compliance & Vulnerability Remediation solution. It walks a novice administrator through mapping the **HIPAA Security Rule** (45 CFR Part 164, Subpart C) technical safeguards and the **HITRUST CSF** control expectations to enforceable, auditable controls on clinical Windows endpoints — using **Microsoft Intune** and **Microsoft Defender for Endpoint (Defender Vulnerability Management)** on a **US sovereign-cloud (GCC High)** tenant, with the `.us` **admin portals**, **US Gov service endpoints**, and **US Gov Microsoft Graph**, and the **Commercial-vs-GCC High parity gaps** called out where they change what you can do.

> ***Why a separate Government edition?*** *GCC High is **not** the Commercial portal behind a different sign-in. The admin URLs differ, the device onboarding/telemetry endpoints differ, the Graph environment differs, and **some Intune and Defender capabilities lag, are limited, or are absent** versus Commercial. Following Commercial steps on a GCC High tenant leads you to portals that don't exist there and to features that silently aren't present (most consequentially, several **Windows Update policies** and **classic Autopilot** in Intune). This edition gives you the **sovereign-correct** path.*

Description

The solution operationalizes the loop that auditors actually ask for — **enforce** the control, **gate** access on it with Conditional Access, **remediate** the vulnerabilities the enforcement surfaces, and **produce evidence** that proves it — but every portal, endpoint, and Graph call targets the **US Government cloud**. It delivers a repeatable phase model and five PowerShell tools that all connect to **US Gov Graph** (`-Environment USGov`, `graph.microsoft.us`).

> ***Important — what this is and is not.*** *HIPAA and HITRUST are **frameworks**, not products. This solution provides the **technical enforcement and evidence layer** that supports a compliance program on a sovereign tenant; it does **not** by itself make an organization "HIPAA compliant" or confer any HITRUST certification. Legal compliance and certification require organizational policies, risk analysis, workforce training, business associate agreements, physical safeguards, and (for HITRUST) a formal assessment by an authorized External Assessor. Treat this as the part a Microsoft administrator can build and prove — the device-level safeguards and the evidence that they operate.*

Why this matters

Most healthcare and government organizations can *state* a security policy ("all devices that access ePHI must be encrypted, lock automatically, run antivirus, and stay patched") but cannot *enforce* it on every endpoint or *prove* it on demand. A HIPAA audit (or an OCR investigation after a breach) and a HITRUST assessment both turn on the same question: show me that the safeguard was configured, applied to the in-scope devices, and operating during the period under review. On a GCC High tenant this is harder to get right, because a doc that points you at `security.microsoft.com` or a script that omits `-Environment USGov` silently reaches the **Commercial** cloud and returns nothing — which looks exactly like "no devices / no evidence." This edition removes that failure mode.

The portals you will use (GCC High — memorize these)

Purpose	Commercial URL	**GCC High URL (use this)**
Sign-in / authentication	`login.microsoftonline.com`	`login.microsoftonline.us`
Microsoft Entra admin center	`entra.microsoft.com`	`entra.microsoft.us`

Purpose	Commercial URL	**GCC High URL (use this)**
Azure portal	`portal.azure.com`	`portal.azure.us`
Microsoft Intune admin center	`intune.microsoft.com`	`intune.microsoft.us`
Microsoft Defender portal	`security.microsoft.com`	`security.microsoft.us`
Microsoft Purview / compliance	`compliance.microsoft.com`	`compliance.microsoft.us`
Microsoft 365 admin center	`admin.microsoft.com`	`portal.office365.us`

> *The Defender portal URL differs again for **DoD** (`security.apps.mil`) and **GCC** (`security.microsoft.com`). This solution targets **GCC High** → `security.microsoft.us`. If your tenant is GCC or DoD, substitute the matching portal from the table in `gcc-high-parity-notes.md`. Cited: Microsoft, *"Microsoft Defender for Endpoint for US Government customers"* — Portal URLs.*

Commercial vs GCC High — what's different

Read this before you start. These are the differences that actually change the steps:

• **Different admin portals.** Every portal is a `.us` (or `portal.office365.us`) host, not `.com`. A bookmark that sends you to a `.com` portal is Commercial and will show you the wrong (or an empty) tenant.

• **Different sign-in authority.** Authentication is `login.microsoftonline.us`. Scripts and API clients must target the **US Gov** authority, not the Commercial one.

• **Different Microsoft Graph environment.** Automation connects with `Connect-MgGraph -Environment USGov` (US Gov L4 Graph, `graph.microsoft.us`). Omit it and the session silently talks to the Commercial cloud and returns nothing for your tenant.

• **Different Defender API base URIs.** The Defender for Endpoint API is `https://api-gov.securitycenter.microsoft.us` for **GCC High & DoD** (and `https://api-gcc.securitycenter.microsoft.us` for GCC) — **not** the public `api.securitycenter.microsoft.com`. Cited: Microsoft — *…for US Government customers*, "API."

• **Different device onboarding/telemetry endpoints.** Devices must reach the **US Gov service URLs** (the "Gov/GCC/DoD" connectivity URL lists), not the Commercial MDE endpoints; use the **streamlined** Gov URL list where supported (marked **Preview** — verify). Cited: Microsoft — Required connectivity settings (Gov/GCC/DoD).

• **Intune update-policy and provisioning gaps (design-affecting).** In GCC High, the newer **Windows Update policies — *feature, quality, expedite, driver updates, Autopatch, Delivery Optimization* — are** planned but not yet available**, and** classic Windows Autopilot is not available**. The patch safeguard in this solution therefore uses an** Update ring for Windows 10 and later **(Windows Update for Business rings, a standard MDM feature that** does **work in GCC High) plus the compliance policy's** Minimum OS version** — not the update *policies* or their reports. *Verify current Gov availability before relying on

any of them.* Cited: Microsoft — Intune Government Service overview.

• **Defender parity gaps. Microsoft Threat Experts** and **enterprise IoT security** are **not

available**;** Microsoft Secure Score **is present but** omits some recommendations**.** Defender Vulnerability Management core + premium are available **(the remediation engine works), but** Report inaccuracy **and** Request CVE support **are** not** available in Gov. The full, cited map is in `gcc-high-parity-notes.md`.

> *Everything else — the *shape* of the control set (map → enforce with compliance policy + baselines → gate with Conditional Access → remediate with Defender TVM → evidence) — is the same as Commercial. The prevention/detection/remediation engine is the same underlying technology, built in the Azure US Government environment. Cited: Microsoft — *…for US Government customers*, overview.*

Scope

In scope

• Mapping HIPAA Security Rule technical safeguards and HITRUST CSF control expectations to specific,

enforceable **Intune** and **Defender** settings on a **GCC High** tenant.

• **Intune device compliance policies** for clinical Windows endpoints: BitLocker encryption, screen

lock / inactivity timeout, Microsoft Defender Antivirus healthy + signatures current, firewall enabled, minimum OS build / patch currency, and account/sign-in controls.

• **Intune configuration baselines** (settings catalog / disk-encryption / endpoint-security policies)

that *enforce* what the compliance policy *measures*.

• A **Conditional Access** gate that requires device compliance before access to corporate cloud

resources.

• **Microsoft Defender Vulnerability Management (TVM)** — exposure scoring, security recommendations,

and a remediation workflow with exception handling (core + premium available in GCC High).

• **Evidence and reporting** — audit-ready exports of compliance state, configuration proof, and

exposure/remediation trend, produced by the included US-Gov-Graph scripts.

Out of scope

• Legal interpretation of HIPAA/HITRUST applicability, risk analysis methodology, or any compliance

attestation/certification.

• macOS, iOS/iPadOS, Android, and Linux endpoints (named objects target Windows clinical endpoints; the

pattern is extensible).

• Server, EHR-application, network, and physical safeguards beyond the endpoint.

• The DoD and (Intune-Commercial) GCC clouds beyond the substitution note above — this edition targets

GCC High.

Objects this solution creates (named, and reused across the docs)

You will create and **reuse** these exact objects throughout the guide (created in `intune.microsoft.us` / `entra.microsoft.us`):

Object	Name	Where
Clinical endpoint scope group	`HIPAA – Clinical Endpoints`	Entra (`entra.microsoft.us`) → Groups
Compliance policy	`HIPAA Compliance – Clinical Endpoints – Policy`	Intune → Devices → Compliance
Encryption baseline (BitLocker)	`Encryption – Clinical Endpoints – Baseline`	Intune → Endpoint security → Disk encryption
Lock / auto-logoff baseline	`Lock – Clinical Endpoints – Baseline`	Intune → Devices → Configuration (settings catalog)
Antivirus baseline (Defender AV)	`Antivirus – Clinical Endpoints – Baseline`	Intune → Endpoint security → Antivirus
Firewall baseline	`Firewall – Clinical Endpoints – Baseline`	Intune → Endpoint security → Firewall
Patch baseline (Update ring)	`Patch – Clinical Endpoints – Baseline`	Intune → Devices → Windows → Update rings
Access / sign-in baseline	`Access – Clinical Endpoints – Baseline`	Intune → Devices → Configuration (settings catalog)
Vulnerability remediation task	`Vulnerability – Clinical Endpoints – Remediation`	Defender (`security.microsoft.us`) → Vulnerability management
Conditional Access gate	`Require Compliance – Clinical Endpoints – Gate`	Entra → Conditional Access

The standard deployment model

Like every solution in this library, you follow **Assess** → **Configure** → **Pilot** → **Validate** → **Expand**, with a **gate** at each boundary (do not proceed until the gate passes). Mapped onto the control loop:

1. **Assess** — confirm GCC High tenant, US Gov licensing, roles, `.us` portal access, endpoint reachability, and map controls to settings (`02-requirements.md`, `03-implementation.md` Phase 1).
1. **Configure** — build the compliance policy and configuration baselines (Phase 2).
2. **Pilot** — assign to a pilot subset of `HIPAA – Clinical Endpoints`, gate in **Report-only**.
3. **Validate** — run the included scripts and the Testing Guide (`05-testing.md`); confirm Compliant, safeguards enforced, gate behaves, TVM exposure captured.

1. **Expand** — enable the gate, roll out in waves, and run the Remediate/Evidence/Operate loop

continuously.

Outcomes

After implementing this solution on your GCC High tenant you will have:

1. A documented **control-to-policy mapping** linking each in-scope HIPAA/HITRUST safeguard to a named

Intune/Defender object and a named owner.

1. Clinical Windows endpoints evaluating **Compliant** against an enforced sovereign baseline.
2. A **Conditional Access** gate that blocks non-compliant clinical endpoints from corporate resources.
3. A running **Defender TVM remediation workflow** with measurable exposure reduction and a documented

exception process (built with the two Gov-unavailable functions — *Report inaccuracy*, *Request CVE support* — designed around).

1. **Audit-ready evidence** produced on a schedule from **US Gov Graph**, stored in a defined,

access-controlled evidence repository.

Audience

Healthcare and government IT/security administrators, virtual CISOs and compliance leads, and MSPs delivering managed compliance for regulated sovereign-cloud clients. The pattern applies to any regulated organization on GCC High that must enforce and evidence endpoint security controls.

Sources: Microsoft Learn — "Microsoft Defender for Endpoint for US Government customers" (learn.microsoft.com/defender-endpoint/gov); "Microsoft Intune Government Service overview"; "Network endpoints for US government deployments." Verify all GCC High / DoD specifics against your tenant, as US Gov availability changes over time. See `gcc-high-parity-notes.md` for the full cited parity map.

2. Requirements — HIPAA & HITRUST Endpoint Compliance & Vulnerability Remediation (Intune + Defender) — Government (GCC High)

Each requirement follows the house pattern: **Description / Why / Verify / Implement-if-missing**. Never assume a prerequisite is already in place — verify it, and provision it if it is not. **Every Verify step uses the `.us` portals** and the **US Gov Graph** — a `.com` portal or a Graph session without `-Environment USGov` will show the wrong (or an empty) tenant. See `gcc-high-parity-notes.md` for the cited portal/endpoint/licensing tables.

R1 — GCC High tenant and Intune (government cloud) MDM authority

• **Description:** An active **Microsoft 365 GCC High** tenant with **Microsoft Intune** (government cloud instance) set as the MDM authority.

• **Why:** Compliance policies and configuration baselines are Intune features. On GCC High the Intune service is the physically separate **government cloud** (IL4/IL5) — not the Commercial instance — so you must administer it from `intune.microsoft.us`. (Note: for *Intune*, "GCC" means Commercial; "GCC High"/"DoD" is the government cloud. Cited: Microsoft — Intune Government Service overview.)

• **Verify:** Sign in to the **Microsoft Intune admin center** at `https://intune.microsoft.us` > **Tenant administration** > **Tenant status** and confirm the tenant is active. Confirm the sign-in authority is `login.microsoftonline.us`.

• **Implement if missing:** Provision/activate the GCC High tenant and Intune government licensing; confirm operators can reach `intune.microsoft.us`.

R2 — US Government licensing (Intune + Entra ID P1/P2 + Defender for Endpoint P2)

• **Description:** US-Gov SKUs that provide Intune, Entra ID P1 (Conditional Access), and Defender for Endpoint **Plan 2** (which includes **Defender Vulnerability Management core**) — e.g. **Microsoft 365 E5 for GCC High** / **Microsoft 365 G5 Security for GCC High** / **Microsoft Defender for Endpoint for GCC High**. (**G3 includes Defender for Endpoint Plan 1** only.)

• **Why:** DVM (the remediation phase) and the machine-risk compliance signal require **Defender for Endpoint Plan 2**; the Conditional Access gate requires** Entra ID P1**. Commercial SKU names do not apply on GCC High — use the Gov SKUs.

• **Verify: Defender portal** (`https://security.microsoft.us`) > **Settings** > **Endpoints** > **Licenses**; and **Entra admin center** (`https://entra.microsoft.us`) > **Identity** > **Overview** > **Licenses**. Confirm an Intune-bearing SKU on a pilot user.

• **Implement if missing:** Acquire the matching **GCC High** SKUs (see the licensing table in `gcc-high-parity-notes.md`) and assign to operators and clinical endpoint users.

R3 — Defender for Endpoint (GCC High) onboarding of clinical endpoints

• **Description:** Clinical Windows endpoints onboarded to **Defender for Endpoint for GCC High** so they report sensor data and TVM exposure, using the **US Gov** onboarding/telemetry endpoints.

• **Why:** A device that is not onboarded contributes no vulnerability data and cannot be remediated through TVM; it is invisible to the exposure score. On GCC High the device must reach the **Gov/GCC/DoD connectivity URLs**, not the Commercial MDE endpoints — the number-one cause of "onboarded but no data" is a device pointed at the Commercial cloud.

• **Verify: Defender portal** (`https://security.microsoft.us`) > **Assets** > **Devices** and confirm the clinical endpoints show **Onboarding status = Onboarded** and **Sensor health = Active**.

• **Implement if missing:** In **Intune admin center** (`https://intune.microsoft.us`) > **Endpoint security > Microsoft Defender for Endpoint, confirm the connector shows** Connected **and turn on** Allow Microsoft Defender for Endpoint to enforce Endpoint Security Configurations**; deploy the onboarding (EDR) policy to** `HIPAA – Clinical Endpoints` **(R5). Allow the** Gov/GCC/DoD **URL lists through proxies/firewalls (use the** streamlined **list where supported — *Preview, verify for GCC High*). For downlevel/MMA devices choose** Azure US Government **(or set** `OPINSIGHTS_WORKSPACE_AZURE_CLOUD_TYPE=1`**) and deploy the required KB** before** onboarding. Cited: Microsoft — Required connectivity settings (Gov/GCC/DoD).

R4 — Administrative roles with least privilege (in the Gov portals)

• **Description:** Operators hold scoped roles — **Intune Administrator**, **Security Administrator**, **Conditional Access Administrator** — assigned in `entra.microsoft.us`, rather than Global Administrator for day-to-day work.

• **Why:** HIPAA and HITRUST expect least-privilege access and separation of duties; over-privileged admin accounts are a top audit finding and breach vector. Roles must be assigned in the **Gov** Entra portal to take effect on the Gov tenant.

• **Verify: Entra admin center** (`https://entra.microsoft.us`) > **Roles & admins** — review assignments; confirm Global Administrator is limited and, where Entra ID P2 is available, PIM-eligible.

• **Implement if missing:** Assign scoped roles; make privileged roles **eligible** via Privileged Identity Management with approval and time limits where licensed.

R5 — The clinical endpoint group `HIPAA – Clinical Endpoints`

• **Description:** A Microsoft Entra security group named `HIPAA – Clinical Endpoints` (created in `entra.microsoft.us`) containing every Windows device in scope for HIPAA/HITRUST endpoint enforcement (dynamic membership preferred).

• **Why:** Every policy, baseline, onboarding profile, and the Conditional Access gate target this single named group. A consistent, accurate scope is the difference between "all clinical devices are enforced" and a silent gap. Use one group, named verbatim, so assignment is unambiguous and auditable.

• **Verify: Entra admin center** (`https://entra.microsoft.us`) > **Groups** > search **`HIPAA – Clinical Endpoints`**; confirm it exists, its membership rule, and expected members.

• **Implement if missing: Entra admin center** > **Groups** > **New group** > Type **Security**, Name `HIPAA – Clinical Endpoints`. For dynamic device membership use a rule such as `(device.deviceOSType -eq "Windows") and (device.deviceCategory -eq "Clinical")` (or a naming-convention rule matching your asset standard). The included `HIPAACOMPG-Set-ScopeTargeting.ps1` can create this group on the Gov tenant. Document the rule with the control owner (R10).

R6 — BitLocker-capable devices (TPM) + Intune disk-encryption policy availability

• **Description:** Clinical endpoints with a TPM (1.2/2.0) and UEFI firmware capable of BitLocker

full-disk encryption, managed by the Intune **Disk encryption (BitLocker)** endpoint-security policy — a standard MDM feature available in GCC High.

• **Why:** Encryption-at-rest is the single most leveraged HIPAA technical safeguard for lost/stolen

devices (the practical basis for the breach-notification safe harbor). If hardware cannot do BitLocker, the encryption control cannot be enforced.

• **Verify:** On a sample device run `manage-bde -status` (usable TPM + encryptable volume), or check

Intune admin center (`https://intune.microsoft.us`) > **Devices** > (device) > **Hardware** for TPM presence; review **Endpoint security** > **Disk encryption** reporting.

• **Implement if missing:** Enable/clear the TPM and enable UEFI Secure Boot in firmware; replace

hardware that lacks a TPM. Deploy the BitLocker policy (implementation Step 4).

R7 — Patch / update currency via Update rings (not update *policies* on GCC High)

• **Description:** A managed update mechanism keeping clinical endpoints on a supported, current build —

delivered by an **Update ring for Windows 10 and later** (Windows Update for Business rings) assigned to `HIPAA – Clinical Endpoints`.

• **Why:** The compliance policy measures **Minimum OS version** (patch currency); without a managed

update flow, devices drift out of compliance and accumulate TVM vulnerabilities. **GCC High caveat:** the newer Intune **Windows Update policies** — *feature, quality, expedite, driver updates, Autopatch, Delivery Optimization* — are **planned but not yet available** in GCC High, and the *feature-update reports* are absent. **Update rings are a standard MDM feature and do work in GCC High** — use them. *Verify current Gov availability of any update policy before relying on it.* Cited: Microsoft — Intune Government Service overview.

• **Verify: Intune admin center** (`https://intune.microsoft.us`) > **Devices** > **Windows** >

Update rings for Windows 10 and later and confirm a ring targets `HIPAA – Clinical Endpoints`.

• **Implement if missing:** Create an **Update ring** named `Patch – Clinical Endpoints – Baseline`

with appropriate deferral/deadline settings; verify devices report a current build. Advance the compliance policy **Minimum OS version** on a schedule (R7 ↔ Best Practices).

R8 — Conditional Access readiness (break-glass + report-only) in Gov Entra

• **Description:** A break-glass (emergency access) account excluded from all Conditional Access, and

the ability to deploy the gate in **Report-only** first — all configured in `entra.microsoft.us`.

• **Why:** A compliance gate that blocks non-compliant devices can lock out administrators if misconfigured. A break-glass account and a report-only rollout prevent a self-inflicted outage.

• **Verify: Entra admin center** (`https://entra.microsoft.us`) > **Protection** > **Conditional Access** — confirm a cloud-only break-glass account exists and is excluded; confirm report-only mode is available.

• **Implement if missing:** Create a cloud-only emergency access account with a long, stored credential, exclude it from all CA policies, and monitor its sign-ins. Roll the gate out in **Report-only** before **On**.

R9 — Control mapping document and evidence ownership

• **Description:** A maintained mapping tying each in-scope HIPAA Security Rule safeguard and HITRUST CSF control to the named Intune/Defender object that enforces it, the evidence source, and the owner.

• **Why:** Assessors do not accept "Intune is configured" — they trace a specific control to a specific enforcement and an accountable owner. The mapping is the spine of the audit narrative and is referenced by every later phase.

• **Verify:** Confirm a current mapping artifact exists (the implementation produces the structure) and that each row names a safeguard, an enforcing object, an evidence source, and an owner.

• **Implement if missing:** Build the mapping in the Assess phase; store it in the evidence repository (R11) and review it at each change (R12).

R10 — Named control owner / accountable role

• **Description:** A designated owner (security/compliance lead) accountable for the endpoint control set, exceptions, and evidence.

• **Why:** HIPAA requires assigned security responsibility; HITRUST control maturity is graded partly on defined accountability. Unowned controls drift and exceptions accumulate silently.

• **Verify:** Confirm the owner is named in the control mapping (R9) and that exception approvals route to that role.

• **Implement if missing:** Assign the role formally, record it in the mapping, and route the exception and change processes (R12) through it.

R11 — Evidence store / repository (sovereign)

• **Description:** A defined, access-controlled location — on the **GCC High** tenant (e.g. a restricted

SharePoint/document library in `portal.office365.us` or a secured share) — to retain generated evidence for the required retention period.

• **Why:** Evidence that is not retained cannot be produced for an audit covering a past period. HIPAA documentation retention is six years; HITRUST assessments review a defined look-back window. On a sovereign tenant, keep the evidence store **inside the Gov boundary**.

• **Verify:** Confirm a repository exists with access limited to the owner and assessors and a retention setting applied.

• **Implement if missing:** Provision a restricted repository within the GCC High tenant, apply retention, and point the reporting script output (`HIPAACOMPG-Report.ps1`) at it.

R12 — Change control and exception process

• **Description:** A lightweight change-control and exception process for the compliance baseline, the CA gate, and TVM remediation deferrals.

• **Why:** Auditors expect that control changes and risk-accepted exceptions are reviewed, approved by the owner, time-bound, and documented — not made ad hoc. **GCC High note:** the Defender **Report inaccuracy** and **Request CVE support** functions are **not available** in Gov, so record any recommendation-accuracy concern or CVE-coverage gap **in your own change record**, not via the portal.

• **Verify:** Confirm a process exists for proposing/approving changes to the named objects and for recording TVM exceptions with justification, approver, and expiry.

• **Implement if missing:** Adopt a simple approval workflow gated by the owner (R10); record exceptions in Defender TVM with a documented justification and review date, mirrored in the evidence store.

> *See* `source/global-requirements-healthcare-solutions.md` *for category-wide requirements common to all Healthcare Solutions (tenant, roles, network, data-handling) — apply them using the* `.us` *portals on a GCC High tenant. See* `gcc-high-parity-notes.md` *for the cited portal/endpoint/ licensing/parity tables. The requirements above are specific to this solution.*

3. Implementation — HIPAA & HITRUST Endpoint Compliance & Vulnerability Remediation (Intune + Defender) — Government (GCC High)

This implementation follows the phase model **Assess** → **Configure** → **Gate** → **Remediate** → **Evidence/Report** → **Operate**, aligned to the library standard **Assess** → **Configure** → **Pilot** → **Validate** → **Expand**. Every object is **named verbatim** using the `<Purpose> – <Scope> – <Stage>` convention and reused across phases, scripts, and evidence. Reuse the exact names. **Every navigation path uses the** `.us` **GCC High portals** — never assume a prerequisite; if a referenced object does not exist, build it per `02-requirements.md` first.

> ***Reminder:*** *This builds the technical enforcement and evidence layer on a sovereign tenant. It does not constitute HIPAA compliance or HITRUST certification on its own.*
>
> ***Before you click anything — confirm you are on GCC High.*** *Sign in at* `https://intune.microsoft.us` *(not* `intune.microsoft.com`*). If a bookmark or search result lands you on a* `.com` *portal, you are on the* ***Commercial*** *cloud and your GCC High objects will not appear. Run* `HIPAACOMPG-Discovery.ps1` *(which connects with* `-Environment USGov`*) to confirm the tenant is reachable before building.*

Phase 1 — Assess: map controls to enforceable settings

Step 1 — Confirm the scope group exists (Gov Entra)

1. Open the **Microsoft Entra admin center** at `https://entra.microsoft.us` > **Identity** > **Groups** > **All groups**.
1. Search for `HIPAA – Clinical Endpoints`. Confirm it is a **Security** group and its (preferably dynamic) device membership rule resolves the in-scope clinical Windows endpoints.
1. If it does not exist, create it per `02-requirements.md` R5 (or run `HIPAACOMPG-Set-ScopeTargeting.ps1`) before proceeding. Every object below targets this group.

Step 2 — Build the control-to-policy mapping

Create the mapping artifact that ties each in-scope safeguard to the object that will enforce it, the evidence source, and the owner. Store it in the evidence repository (R11). Use this structure (named objects are created in later phases):

HIPAA Security Rule safeguard	HITRUST CSF area	Enforcing object (named)	Evidence source	Owner
Encryption & decryption — §164.312(a)(2)(iv)	06 Configuration / 19 Data Protection	`Encryption – Clinical Endpoints – Baseline` (BitLocker)	Intune disk-encryption report; `HIPAACOMPG-Report.ps1`	(R10)
Automatic logoff — §164.312(a)(2)(iii)	01 Access Control	`Lock – Clinical Endpoints – Baseline` (inactivity lock/timeout)	Compliance + config report	(R10)
Protection from malicious software — §164.308(a)(5)(ii)(B)	09 Endpoint Protection	`Antivirus – Clinical Endpoints – Baseline` (Defender AV)	Defender AV health; compliance report	(R10)

HIPAA Security Rule safeguard	HITRUST CSF area	Enforcing object (named)	Evidence source	Owner
Integrity / network safeguards — §164.312(c)(1)	09 Network Protection	`Firewall – Clinical Endpoints – Baseline` (Windows Firewall)	Config report	(R10)
Security updates / patch — §164.308(a)(1)(ii)(B)	10 Vulnerability Mgmt	`Patch – Clinical Endpoints – Baseline` (Update ring; min OS build)	Compliance report; Defender TVM	(R10)
Access control / unique user ID — §164.312(a)(2)(i)	01 Access Control	`Access – Clinical Endpoints – Baseline` (account/sign-in controls)	Config report	(R10)
Vulnerability exposure management	10 Vulnerability Mgmt	Defender TVM + `Vulnerability – Clinical Endpoints – Remediation`	Defender exposure score; `HIPAACOMPG-Report.ps1`	(R10)
Access enforcement at sign-in	01 Access Control	`Require Compliance – Clinical Endpoints – Gate` (Conditional Access)	CA sign-in logs	(R10)

The mapping is the audit spine. Keep it current as objects are created and renamed.

Phase 2 — Configure: compliance policy and configuration baselines

The **compliance policy measures** the safeguards; the **configuration baselines enforce** them. Build both, in `intune.microsoft.us`. You may scaffold the compliance policy + CA gate first with `HIPAACOMPG-Set-ScopeTargeting.ps1`–adjacent tooling, or build by hand as below.

Step 3 — Create the compliance policy `HIPAA Compliance – Clinical Endpoints – Policy`

1. **Intune admin center** (`https://intune.microsoft.us`) > **Devices** > **Compliance** >

Compliance policies > **+ Create policy**.

1. **Platform:** *Windows 10 and later*. Click **Create**.

2. **Basics:** Name = `HIPAA Compliance – Clinical Endpoints – Policy`; Description = "Measures

HIPAA/HITRUST endpoint safeguards on GCC High: BitLocker, lock, Defender AV, firewall, patch currency, sign-in. Targets HIPAA – Clinical Endpoints." Click **Next**.

1. **Compliance settings** — expand each section and set:

• **Device Health:** *Require BitLocker* = **Require**; *Require Secure Boot to be enabled* = **Require**; *Require code integrity* = **Require**.

• **Device Properties:** *Minimum OS version* = your current supported Windows build (drives patch currency; update as builds advance — see R7).

• **System Security:**

• *Require a password to unlock mobile devices* = **Require**; *Maximum minutes of inactivity before password is required* = **15** (automatic logoff).

• *Encryption of data storage on device* = **Require**; *Firewall* = **Require**.

• *Antivirus* = **Require**; *Antispyware* = **Require**.

• *Microsoft Defender Antimalware* = **Require**; *Real-time protection* = **Require**; *Microsoft Defender Antimalware security intelligence up-to-date* = **Require**.

• **Microsoft Defender for Endpoint:** *Require the device to be at or under the machine risk score* = **Medium** (requires the Defender-for-GCC-High connector, R3).

1. **Actions for noncompliance:** keep *Mark device noncompliant* = **Immediately**; add *Send email to end user*. Click **Next**.

1. **Scope tags:** apply your scope tag if used. **Assignments: Included groups** > add **`HIPAA – Clinical Endpoints`. Click** Next **>** Create**.

> ***Verify: Devices*** *>* ***Compliance*** *> open the policy >* ***Device status*** *— devices report within an evaluation cycle. If none appear, confirm you are on* `intune.microsoft.us` *(not* `.com`*).*

Step 4 — Create `Encryption – Clinical Endpoints – Baseline` *(BitLocker)*

1. **Intune admin center** > **Endpoint security** > **Disk encryption** > **+ Create policy**.

2. **Platform** = *Windows 10 and later*; **Profile** = *BitLocker*. **Create**.

3. **Basics:** Name = `Encryption – Clinical Endpoints – Baseline`; Description = "Enforces BitLocker

silent encryption for clinical endpoints (HIPAA encryption safeguard)."

1. **Configuration settings:**

• *Enable full disk encryption for OS and fixed data drives* = **Yes**.

• **BitLocker – Base Settings:** *Allow standard users to enable encryption during Autopilot* =

Yes *(note: classic Autopilot is not available on GCC High — this setting is harmless but has no effect without Autopilot; standard silent encryption still applies on enrollment)*; *Configure client-driven recovery password rotation* = **Enabled for Azure AD-joined devices**.

• **BitLocker – OS Drive Settings:** *Startup authentication required* = **Yes**; *Compatible TPM

startup* = **Required**; *Recovery options* > *Save BitLocker recovery information to Microsoft Entra ID* = **Yes**; *Store recovery information before enabling* = **Yes**.

1. **Assignments:** add `HIPAA – Clinical Endpoints`. **Create**.

> ***Verify: Endpoint security*** *>* ***Disk encryption*** *> the policy > encryption status; and* ***Devices*** *> (device) >* ***Recovery keys*** *shows escrowed keys (escrowed to the* ***Gov*** *directory).*

Step 5 — Create `Lock – Clinical Endpoints – Baseline` *(automatic logoff)*

1. **Intune admin center** > **Devices** > **Configuration** > **+ Create** > **New policy**.
2. **Platform** = *Windows 10 and later*; **Profile type** = *Settings catalog*. **Create**.
3. **Basics:** Name = `Lock – Clinical Endpoints – Baseline`; Description = "Enforces automatic screen

lock / inactivity timeout (HIPAA automatic logoff)."

1. **Configuration settings** > **+ Add settings** > search **Device Lock** and add:

• *Maximum Inactivity Time Lock Screen* = **15** (minutes).

• Machine inactivity limit (Local Policies Security Options > *Interactive logon: Machine inactivity

limit*) = **900** seconds.

• *Require password when device returns from idle* = **Enabled**.

1. **Assignments:** add `HIPAA – Clinical Endpoints`. **Create**.

Step 6 — Create `Antivirus – Clinical Endpoints – Baseline` *(Defender AV)*

1. **Intune admin center** > **Endpoint security** > **Antivirus** > **+ Create policy**.
2. **Platform** = *Windows 10, Windows 11, and Windows Server*; **Profile** = *Microsoft Defender

Antivirus*. **Create**.

1. **Basics:** Name = `Antivirus – Clinical Endpoints – Baseline`; Description = "Enforces Microsoft

Defender Antivirus real-time + cloud protection and signature currency (HIPAA malware protection)."

1. **Configuration settings:** *Allow Realtime Monitoring* = **Allowed**; *Allow Cloud Protection* =

Allowed; *Cloud Block Level* = **High**; *Allow Behavior Monitoring* = **Allowed**; *Submit Samples Consent* = **Send safe samples automatically**; *Signature Update Interval* = **4** (hours); *Allow Scanning Network Files* = **Allowed**; schedule a daily quick scan.

1. **Assignments:** add `HIPAA – Clinical Endpoints`. **Create**.

> ***GCC High note:*** *cloud protection and signature updates flow to the* ***US Gov*** *service endpoints. If AV reports unhealthy or signatures stale, the usual cause is a proxy/firewall not allowing the*

***Gov/GCC/DoD** connectivity URLs (see `06-troubleshooting.md`).*

Step 7 — Create `Firewall – Clinical Endpoints – Baseline`

1. **Intune admin center** > **Endpoint security** > **Firewall** > **+ Create policy**.

2. **Platform** = *Windows 10, Windows 11, and Windows Server*; **Profile** = *Microsoft Defender

Firewall*. **Create**.

1. **Basics:** Name = `Firewall – Clinical Endpoints – Baseline`; Description = "Enforces Windows

Defender Firewall on all profiles (HIPAA network safeguard)."

1. **Configuration settings:** for **Domain**, **Private**, and **Public** profiles set *Enable Firewall*

= **True**; *Inbound connections blocked* = **True** (default); *Outbound connections required* = **Allowed**.

1. **Assignments:** add `HIPAA – Clinical Endpoints`. **Create**.

Step 8 — Create `Patch – Clinical Endpoints – Baseline` *(Update ring) and* `Access – Clinical Endpoints – Baseline`

1. **Patch (Update ring — the GCC-High-correct patch mechanism): Devices** > **Windows** > **Update

rings for Windows 10 and later **>** + Create profile**. Name =** `Patch – Clinical Endpoints – Baseline`**; set sensible quality/feature deferral and deadlines;** Assign **to** `HIPAA – Clinical Endpoints`**.** Create.**

> ***GCC High caveat:** do **not** try to use the newer **Feature updates / Quality updates / Expedite updates / Driver updates** *policies* or **Autopatch** — they are **planned but not yet available** on GCC High, and *feature-update reports* are absent. **Update rings work** and are what this solution uses. *Verify current Gov availability before relying on any update policy.* Cited: Microsoft — Intune Government Service overview.*

1. **Access: Devices** > **Configuration** > **+ Create** > **New policy** > *Windows 10 and later* >

Settings catalog. Name = `Access – Clinical Endpoints – Baseline`; Description = "Enforces account/sign-in controls (HIPAA access control / unique user ID)." Add: *Limit Local Account Use Of Blank Passwords To Console Logon Only* = **Enabled**; *Account Lockout Threshold* = **10**; *Minimum Password Length* per policy; *Interactive logon: Do not display last signed-in* = **Enabled**; disable built-in Guest. **Assign** to `HIPAA – Clinical Endpoints`. **Create.**

> *Optionally apply a Microsoft **Security baseline** (Endpoint security > Security baselines) to `HIPAA – Clinical Endpoints` for breadth, after reconciling conflicts with the targeted baselines above. Confirm the baseline you want is present on your GCC High tenant first — some baseline versions roll out to Gov later than Commercial (*verify for GCC High*).*

Phase 3 — Gate: Conditional Access on compliance (Gov Entra)

Step 9 — Create the Conditional Access gate `Require Compliance – Clinical Endpoints – Gate`

1. **Microsoft Entra admin center** (`https://entra.microsoft.us`) > **Protection** > **Conditional

Access **>** Policies **>** + New policy**.

1. **Name:** `Require Compliance – Clinical Endpoints – Gate`.

2. **Users:** Include the gated population (clinical staff group); **Exclude** the break-glass account (R8) and any service accounts.

1. **Target resources:** *Cloud apps* > **All cloud apps** (or scope to the resources holding ePHI). Note the app catalog reflects your **GCC High** tenant's apps.

1. **Conditions:** *Device platforms* = **Windows**.

2. **Grant:** *Grant access* > check **Require device to be marked as compliant**; set **Require all the selected controls**.

1. **Enable policy:** set to **Report-only** first. Click **Create**.

2. After validating impact in report-only (see `05-testing.md`), edit the policy and set **Enable policy = On**.

> ***Verify:*** *A non-compliant clinical Windows device is blocked from the target resource; a compliant one is allowed. Review* ***Entra*** *(`entra.microsoft.us`) >* ***Monitoring*** *>* ***Sign-in logs*** *>* ***Conditional Access*** *tab.*

Phase 4 — Remediate: Defender Vulnerability Management workflow (Gov Defender portal)

Step 10 — Establish exposure baseline in Defender TVM

1. **Microsoft Defender portal** (`https://security.microsoft.us`) > **Vulnerability management** >

Dashboard.

1. Record the current **Exposure score** and **Microsoft Secure Score for Devices** as the baseline (store in the evidence repository, R11).

> ***GCC High note: Secure Score is available but omits some recommendations*** *in Gov — so a figure or recommendation you saw in Commercial may differ or be absent. Record what your Gov tenant shows; do not expect Commercial-identical numbers. Cited: Microsoft — Feature parity note.*

1. Filter by the device group corresponding to `HIPAA – Clinical Endpoints` (create/confirm a matching **device group** under **Settings** > **Endpoints** > **Device groups** if Defender RBAC device groups are used).

Step 11 — Triage and drive `Vulnerability – Clinical Endpoints – Remediation`

1. **Vulnerability management** > **Recommendations**. Sort by impact/exposure for the clinical device group.

1. For each top recommendation, open it and review **Exposed devices** and **Remediation options**.

2. Click **Request remediation** to create a task titled with the prefix **`Vulnerability – Clinical Endpoints – Remediation`**; route it via the integrated** Intune** remediation request (the Intune ↔ Defender connector works on GCC High) or as a tracked task; set a due date.

1. Track open tasks under **Vulnerability management** > **Remediation**. **Patch-type** recommendations are closed by the **Update ring** (`Patch – Clinical Endpoints – Baseline`); **configuration-type** by the matching baseline.

Step 12 — Handle exceptions (GCC High specifics)

1. For a recommendation that cannot be remediated now (clinical/medical-device dependency, vendor constraint), open it > **Exception options** > **Create exception**; choose **justification** and **scope**, set an **expiry**.

1. Record the exception (justification, approver = R10, expiry) in the evidence repository per R12.

> ***GCC High caveat:*** *the Defender **Report inaccuracy** and **Request CVE support** functions are **not available** in Gov. If a recommendation looks wrong, or a CVE you care about is not covered, you **cannot** submit it from the portal — record the concern in your **own** change record (R12) and follow up through your Microsoft support channel. Cited: Microsoft — DVM functionality not available for GCC/GCC High/DoD.*

Phase 5 — Evidence / Report: produce audit-ready output (from US Gov Graph)

Step 13 — Capture compliance and configuration evidence

1. **Intune admin center** (`https://intune.microsoft.us`) > **Devices** > **Compliance** > **`HIPAA Compliance – Clinical Endpoints – Policy`** > Device status / Per-setting status** — export.

1. **Reports** > **Device compliance** — run **Device compliance** and **Noncompliant devices**; export to the evidence store (R11).

1. **Endpoint security** > **Disk encryption** — export BitLocker/encryption status as encryption proof.

2. Run `HIPAACOMPG-Report.ps1` (connects `-Environment USGov`) to generate a consolidated CSV (per-device compliance, key safeguard status, exposure context) — written to the Gov evidence repository.

Step 14 — Capture vulnerability/remediation evidence

1. **Defender portal** (`https://security.microsoft.us`) > **Vulnerability management** > **Dashboard** — export exposure score and trend; **Recommendations** and **Remediation** — export open/closed task status and exceptions.

1. Compare current exposure to the Step 10 baseline to demonstrate reduction. Store all exports date-stamped in the evidence repository.

Phase 6 — Operate: run the control set over time

Step 15 — Operationalize the recurring loop

1. Schedule `HIPAACOMPG-Validation.ps1` (per-device PASS/FAIL) and `HIPAACOMPG-Report.ps1` on a

cadence; deposit output in the Gov evidence store.

1. Review noncompliant devices and remediate (`HIPAACOMPG-Remediation.ps1` in default `-WhatIf`

first, then `-WhatIf:$false -Confirm:$false` to apply).

1. Advance the *Minimum OS version* in the compliance policy as Windows builds progress (keeps the

patch-currency bar current, paired with the Update ring).

1. Review TVM exceptions at expiry and reassess exposure each period; update the control mapping

(Step 2) on any change, gated by change control (R12).

1. Re-run `HIPAACOMPG-Discovery.ps1` periodically to detect drift (policies present, Defender-for-Gov

onboarding, CA gate, BitLocker state) — and to reconfirm you are still reaching the **US Gov** cloud.

> ***Done means:*** *clinical endpoints evaluate Compliant against the enforced baselines on GCC High, the CA gate blocks non-compliant devices, TVM exposure trends down, and dated evidence is retained in the sovereign repository — all traceable through the control mapping to a named owner.*

5. Testing & Validation — HIPAA & HITRUST Endpoint Compliance & Vulnerability Remediation (Intune + Defender) — Government (GCC High)

Validate against explicit gates. Each gate has a **Test**, an **Expected result**, and **Evidence**. A gate is **PASS** only when the expected result is observed and evidence is stored in the repository (R11). Run gates after each phase and again as a full pass before declaring the solution operational. All supplied scripts default to read-only and connect with `-Environment USGov`.

> *Testing proves the **technical controls** operate and produce evidence on a sovereign tenant. It is not a HIPAA audit or a HITRUST assessment.*

Gate 0 — You are on the GCC High cloud (do this first)

• **Test:** Run `HIPAACOMPG-Discovery.ps1`. Confirm the connection banner reports **Environment:

USGov** and your GCC High tenant id, and that managed devices are listed.

• **Expected:** `Get-MgContext` Environment = **USGov**; devices returned. An **empty result** or a

Commercial-authority error means the session reached the wrong cloud — see `06-troubleshooting.md`, section F.

- **Evidence:** Discovery console output showing Environment = USGov, stored with date.

Gate 1 — Tenant readiness (Assess/Configure prerequisites)

- **Test:** From `HIPAACOMPG-Discovery.ps1` output, confirm the named compliance policy and configuration baselines exist and are assigned to `HIPAA – Clinical Endpoints`; Defender-for-GCC-High onboarding is active; the CA gate exists; BitLocker policy is present.
- **Expected:** All named objects present and assigned; Defender connector healthy in `security.microsoft.us`; `Require Compliance – Clinical Endpoints – Gate` found; no missing prerequisites.
- **Evidence:** Discovery output (console/CSV) stored with date.

Gate 2 — Devices evaluate Compliant

- **Test:** On enrolled clinical endpoints, force a sync (Settings > Accounts > Access work or school > Info > Sync) and wait an evaluation cycle. In **Intune admin center** (`https://intune.microsoft.us`) ***Devices*** > ***Compliance*** > `HIPAA Compliance – Clinical Endpoints – Policy` > ***Device** status**, review state. Run `HIPAACOMPG-Validation.ps1` per device.
- **Expected:** Target clinical endpoints report **Compliant**; validation returns **PASS** for each in-scope device (any FAIL identifies a real gap).
- **Evidence:** Intune compliance export + validation PASS/FAIL output.

Gate 3 — Conditional Access blocks non-compliant devices

- **Test:** From a deliberately non-compliant clinical Windows device, attempt to access a gated resource; then repeat from a compliant device. Confirm via **Entra** (`entra.microsoft.us`) > **Monitoring** > **Sign-in logs** > **Conditional Access** tab for `Require Compliance – Clinical Endpoints – Gate`.
- **Expected:** Non-compliant device **blocked** (policy Not satisfied); compliant device **allowed** (Success). Break-glass account unaffected.
- **Evidence:** Sign-in log entries (both outcomes) exported; screenshot of the block.

Gate 4 — Key safeguards enforced

Verify each safeguard is actually enforced on a sample device (not merely measured):

- **BitLocker / encryption:** `manage-bde -status` shows the OS volume **Fully Encrypted**; recovery key escrowed to the **Gov** directory (Intune > device > Recovery keys). **Expected:** encrypted + key present.

• **Automatic lock / timeout:** device locks after the configured inactivity period (15 min).

Expected: screen locks, password required on resume.

• **Antivirus (Defender):** `Get-MpComputerStatus` shows *RealTimeProtectionEnabled = True*, *AntivirusSignatureAge* low, cloud protection on. **Expected:** real-time on, signatures current (updated from the **US Gov** service endpoints).

• **Firewall:** `Get-NetFirewallProfile` shows **Enabled = True** for Domain/Private/Public.

Expected: all profiles enabled.

• **Patch currency:** device build ≥ the compliance policy *Minimum OS version*, driven by the **Update ring** (`Patch – Clinical Endpoints – Baseline`). **Expected:** at/above the bar.

• **Evidence:** command output / config report per safeguard, captured by `HIPAACOMPG-Validation.ps1` and stored.

Gate 5 — TVM exposure reduced

• **Test:** Compare the current **Exposure score** for the clinical device group in **Defender portal** (`https://security.microsoft.us`) > **Vulnerability management** > **Dashboard** against the Step 10 baseline after remediation (`Vulnerability – Clinical Endpoints – Remediation`) and patching. Run `HIPAACOMPG-Report.ps1` to capture exposure context.

• **Expected:** Exposure score **lower** than baseline (or top recommendations closed); open remediation tasks trending down; documented exceptions only.

• **Evidence:** Dashboard export (baseline vs current), remediation/exception status, report CSV.

> ***GCC High note:*** *if a specific Secure Score recommendation you expected is absent, that may be an* ***expected Gov parity gap****, not a failure — confirm against* `gcc-high-parity-notes.md` *before treating it as a defect.*

Gate 6 — Evidence produced and retained (sovereign)

• **Test:** Run `HIPAACOMPG-Report.ps1` and confirm a consolidated CSV (per-device compliance, safeguard status, exposure context) is written to the **GCC High** evidence repository; confirm Intune/Defender exports are date-stamped and retained.

• **Expected:** Complete, dated evidence set present in the access-controlled sovereign repository; contents are configuration/compliance metadata only (no ePHI, per GR6).

• **Evidence:** The report file itself + repository listing showing retention.

Regression / ongoing validation

• Re-run **Gate 0** whenever a script returns nothing — the most common GCC High regression is a session

that reached the Commercial cloud.

- Re-run **Gate 1** (Discovery) periodically to catch drift (deleted/unassigned policy, Defender

connector failure, CA gate disabled).

- Re-run **Gate 2/4** (Validation) on the recurring cadence; investigate any new FAIL.
- Re-run **Gate 5** each period; re-run **Gate 3** after any CA change.
- For remediation, always run `HIPAACOMPG-Remediation.ps1` in default `-WhatIf` mode and review the

planned action before `-WhatIf:$false -Confirm:$false`.

> *A full PASS across Gates 0–6 with stored evidence is the bar for "operational." Re-test after any change to a named object, gated by change control (R12).*

6. Troubleshooting — HIPAA & HITRUST Endpoint Compliance & Vulnerability Remediation (Intune + Defender) — Government (GCC High)

Common failure modes across the six phases, with likely cause and fix — tuned for a **GCC High** tenant. **Run** `HIPAACOMPG-Discovery.ps1` **first when in doubt** — it confirms you are on the **USGov** cloud and surfaces most readiness gaps. All diagnostic actions are read-only; remediate through the named objects, not by hand. **Section F (wrong-cloud / endpoints) is unique to the Government edition — check it first when a portal is empty or a script returns nothing.**

> *These fix the **technical controls** on a sovereign tenant. They are not a substitute for the organizational elements of a HIPAA/HITRUST program.*

F. GCC High wrong-cloud and endpoint issues (check this first)

A portal shows no tenant / no devices, or "you don't have access"

- *Cause:* You are on a **Commercial (`.com`) portal**, not the GCC High (`.us`) one.
- *Fix:* Use the `.us` portals: `intune.microsoft.us`, `entra.microsoft.us`, `security.microsoft.us`,

`compliance.microsoft.us`, `portal.office365.us`, `portal.azure.us`. Sign in via `login.microsoftonline.us`. Delete `.com` bookmarks. Cited: `gcc-high-parity-notes.md` §1.

A script returns nothing / an authority error / connects to the wrong tenant

- *Cause:* The Graph session reached the **Commercial** cloud because `-Environment USGov` was missing.
- *Fix:* Every included script connects with `-Environment USGov`. Confirm the banner shows

Environment: USGov. If not, `Disconnect-MgGraph` and re-run. Do not remove `-Environment USGov`. Cited: `gcc-high-parity-notes.md` §2.

Device onboarded to Defender but reports no data / stays "not onboarded"

• *Cause:* The device is reaching the **Commercial** MDE endpoints, or the **Gov/GCC/DoD** connectivity

URLs are blocked, or (downlevel/MMA) the wrong Azure Cloud was selected.

• *Fix:* Allow the **Gov/GCC/DoD** URL lists through the proxy/firewall (use the **streamlined** list

where supported — *Preview, verify for GCC High*). For downlevel/MMA choose **Azure US Government** (or `OPINSIGHTS_WORKSPACE_AZURE_CLOUD_TYPE=1`) and deploy the required KB **before** onboarding. Confirm in `security.microsoft.us` > Assets > Devices. Cited: Microsoft — Required connectivity settings (Gov/GCC/DoD); `gcc-high-parity-notes.md` §4.

Custom tooling calling the Defender API fails auth

• *Cause:* Using the public `api.securitycenter.microsoft.com`.

• *Fix:* Use `https://api-gov.securitycenter.microsoft.us` (GCC High & DoD) and sign in at

`login.microsoftonline.us`. Cited: `gcc-high-parity-notes.md` §2.

A feature/report/dashboard from Commercial docs is missing

• *Cause:* A **Gov parity gap** — the capability is not yet available in GCC High, or Secure Score omits

the recommendation.

• *Fix:* Check `gcc-high-parity-notes.md` §5–§7. Notably: **Windows Update *policies*** (feature/quality/

expedite/driver, Autopatch) and **classic Autopilot** are **not available** on GCC High; use **Update rings** for patching. **DVM Report inaccuracy** and **Request CVE support** are **not available** — use your own change record. Treat anything unconfirmed in your `.us` tenant as absent.

Compliance evaluation

Devices show "Not evaluated" or no compliance state

• *Cause:* Device hasn't synced, isn't enrolled, or the policy isn't assigned to `HIPAA – Clinical

Endpoints` — **or** you are viewing the Commercial portal (see F).

• *Fix:* Confirm enrollment in `intune.microsoft.us` > Devices > device; force sync (Settings > Accounts

Access work or school > Sync); confirm `HIPAA Compliance – Clinical Endpoints – Policy` *assignment*

includes the group and the device is a member. Allow an evaluation cycle.

Device unexpectedly Noncompliant

• *Cause:* A measured safeguard isn't enforced (e.g. the compliance policy requires BitLocker but

`Encryption – Clinical Endpoints – Baseline` didn't apply), or a setting genuinely fails.

• *Fix:* Open the policy > **Device status** > device > **Per-setting status** to find the failing

setting. Verify the matching baseline is assigned and applied. Run `HIPAACOMPG-Validation.ps1` to pinpoint the safeguard.

Compliance and configuration disagree

- *Cause:* Policy measures a setting no baseline enforces.
- *Fix:* Add/repair the enforcing baseline (implementation Steps 4–8); every measured setting needs a

matching baseline.

BitLocker / encryption

BitLocker not encrypting; device fails the encryption check

- *Cause:* No usable TPM, Secure Boot disabled, or the device waiting on user action.
- *Fix:* `manage-bde -status` and check TPM (`tpm.msc`); enable/clear TPM and Secure Boot in firmware

(R6). Confirm `Encryption – Clinical Endpoints – Baseline` is assigned. Replace hardware without a TPM.

Recovery keys not escrowed

- *Cause:* Baseline not set to save recovery info before enabling, or keys expected in the Commercial

directory.

- *Fix:* In `Encryption – Clinical Endpoints – Baseline`, set *Save BitLocker recovery information to

Microsoft Entra ID* = **Yes** and *Store recovery information before enabling* = **Yes**; re-sync. Verify under `intune.microsoft.us` > Devices > device > **Recovery keys** (escrowed to the **Gov** directory).

Automatic lock / antivirus / firewall

Screen doesn't lock on timeout

- *Cause:* `Lock – Clinical Endpoints – Baseline` not applied or overridden.
- *Fix:* Confirm the settings-catalog policy is assigned/applied; check per-setting status for a conflict;

verify *Maximum Inactivity Time Lock Screen* / machine inactivity limit.

Defender AV reported unhealthy / signatures stale

- *Cause:* Cloud/real-time protection off, signature update blocked at the **US Gov** endpoints, or a

third-party AV present.

- *Fix:* `Get-MpComputerStatus`; ensure `Antivirus – Clinical Endpoints – Baseline` enables real-time +

cloud protection and a short signature interval. Confirm the **Gov** update endpoints are reachable (Section F / GR5). Remove/disable conflicting third-party AV (Defender goes passive when another AV is active).

Firewall check fails

- *Cause:* A profile disabled or overridden by GPO/third-party.
- *Fix:* `Get-NetFirewallProfile`; confirm `Firewall – Clinical Endpoints – Baseline` enables all three

profiles; resolve GPO/third-party conflicts.

Conditional Access (the gate)

Compliant users still blocked

- *Cause:* Device not Entra-registered/compliant at token time, or policy scoped too broadly.
- *Fix:* Confirm the device is compliant **and** Entra-joined/registered on the **Gov** tenant; review

`entra.microsoft.us` > Sign-in logs > Conditional Access for the failing control. Re-check the device platform condition and grant control.

Admins locked out / risk of lockout

- *Cause:* No break-glass exclusion, or gate enabled before report-only validation.
- *Fix:* Use the excluded break-glass account (R8) to regain access; set the gate to **Report-only**,

validate, then enable. Always keep break-glass excluded.

Non-compliant device NOT blocked

- *Cause:* Gate still in Report-only, or device/user outside scope.
- *Fix:* Confirm `Require Compliance – Clinical Endpoints – Gate` is **On** in `entra.microsoft.us`, the

user is in the included population, and the device platform/target resource match.

Defender Vulnerability Management

No exposure data / devices missing from TVM

- *Cause:* Devices not onboarded to Defender for GCC High, sensor inactive, or reaching the wrong cloud

(Section F).

- *Fix:* `security.microsoft.us` > Assets > Devices — confirm Onboarded + Active sensor (R3). Re-deploy

onboarding via the Intune connector; confirm **Gov** connectivity URLs (Section F).

Remediation task created but exposure unchanged

- *Cause:* Patch/config not actually deployed, or the recommendation needs the baseline/Update ring.
- *Fix:* Close patch findings via `Patch – Clinical Endpoints – Baseline` (**Update ring** — the update

policies are not available on GCC High); close config findings via the matching baseline. Manual fixes drift back — enforce via policy.

A recommendation looks wrong, or a CVE isn't covered — no portal button to report it

- *Cause:* **Report inaccuracy** and **Request CVE support** are **not available** in GCC High/DoD.
- *Fix:* Record the concern in your **own** change record (R12) and escalate through your Microsoft

support channel; do not expect the portal action. Cited: `gcc-high-parity-notes.md` §5.

Recommendation can't be remediated (medical/vendor device)

- *Cause:* Embedded/unpatchable clinical device.
- *Fix:* Create a Defender **exception** with justification, owner approval (R10), and expiry; record in

the evidence store (R12); compensate with network segmentation.

Patch / updates (GCC High specifics)

"Feature updates / Quality updates / Expedite / Driver update" policy option is missing

- *Cause:* Those update **policies** (and Autopatch/Delivery Optimization) are **planned but not yet

available** on GCC High.

- *Fix:* Use an **Update ring for Windows 10 and later** (`Patch – Clinical Endpoints – Baseline`) plus

the compliance policy **Minimum OS version**. *Re-verify Gov availability periodically.* Cited: Microsoft — Intune Government Service overview; `gcc-high-parity-notes.md` §6.

Evidence / reporting

Report script returns nothing or errors on auth

- *Cause:* Wrong cloud (Section F), missing Graph scopes/modules, or insufficient role.
- *Fix:* Confirm the session is **USGov**; ensure the Microsoft Graph PowerShell SDK is installed and the

operator has read access to Intune/Defender data on the Gov tenant; the script header lists the read scopes. Re-run.

Evidence missing for a past period

- *Cause:* Reports not scheduled/retained.
- *Fix:* Schedule `HIPAACOMPG-Report.ps1` / `HIPAACOMPG-Validation.ps1` on a cadence; write to the

retained, access-controlled **sovereign** repository (R11). You cannot reconstruct past-period evidence after the fact.

Concern: ePHI in evidence

- *Cause:* Report scope too broad.
- *Fix:* Confirm outputs are device/compliance/exposure metadata only (GR6); redact incidental sensitive

values; restrict the repository.

Discovery / drift

Discovery flags a missing named object

- *Cause:* Object deleted, renamed off-convention, or unassigned.

• *Fix:* Recreate/rename to the exact <Purpose> – <Scope> – <Stage> name and reassign to `HIPAA –

Clinical Endpoints (use HIPAACOMPG-Remediation.ps1` to fix assignments); update the control mapping under change control (R12).

7. Best Practices — HIPAA & HITRUST Endpoint Compliance & Vulnerability Remediation (Intune + Defender) — Government (GCC High)

Operational guidance for running the control set well on a sovereign tenant, surviving an audit, and avoiding the failure modes that turn a good baseline into a false sense of security.

> *Reminder: these practices strengthen the **technical enforcement and evidence**. Compliance and certification also require organizational policy, risk analysis, training, BAAs, physical safeguards, and (for HITRUST) authorized assessment.*

Sovereign-cloud hygiene (GCC High first principles)

• **Bookmark the .us portals and delete the .com ones.** Every admin surface is .us

(intune.microsoft.us, entra.microsoft.us, security.microsoft.us, compliance.microsoft.us, portal.office365.us, portal.azure.us). A stray .com bookmark is the single most common way to "lose" your tenant.

• **Every script connects with -Environment USGov.** Confirm the connection banner shows

Environment: USGov before you trust any output. A missing -Environment USGov silently reaches Commercial and returns nothing — which looks exactly like "no devices / no evidence."

• **Keep the evidence store inside the Gov boundary.** Retain compliance/exposure evidence in the GCC

High tenant (R11), not a Commercial SharePoint or a personal share.

• **Verify features before you depend on them.** Government rollout trails Commercial. For any dashboard,

report, connector, or update policy you plan to rely on, confirm it in your .us tenant first and treat anything unconfirmed as absent (see gcc-high-parity-notes.md).

Naming and traceability

• **Use the <Purpose> – <Scope> – <Stage> names verbatim** across Intune, Defender, the CA gate,

scripts, and evidence. Consistent names let an assessor trace control → object → evidence in seconds.

• **One scope group, named once.** Assign every object to HIPAA – Clinical Endpoints. Divergent

scope is the most common silent gap.

• **Keep the control mapping current** — a living artifact updated whenever an object is created, renamed, or retired, under change control.

Compliance policy design

• **Measure what you enforce.** Every setting in the compliance policy must have a matching configuration baseline that enforces it. A policy that *measures* BitLocker without a baseline that *deploys* it just reports failure.

• **Advance the patch bar deliberately.** Raise *Minimum OS version* on a schedule as Windows builds progress; pair with the **Update ring** (`Patch – Clinical Endpoints – Baseline`) so devices can meet the bar before it rises. On GCC High the ring is your patch mechanism — the newer update *policies* are not yet available.

• **Use Defender machine risk as a compliance signal** so an actively compromised device falls out of compliance and is gated (the Intune ↔ Defender connector works on GCC High).

Conditional Access (the gate)

• **Always roll out in Report-only first**, review impact in `entra.microsoft.us` sign-in logs, then enable. A misconfigured gate can lock clinicians out of the EHR.

• **Keep a tested break-glass account** excluded from all CA policies, with monitored sign-ins and a securely stored credential. Test it before you need it.

• **Scope the gate to the resources that hold ePHI** where possible, to minimize collateral lockout.

• **Account for shared/kiosk clinical workstations** explicitly — confirm the gate behaves correctly with shared sign-in patterns.

Vulnerability management (Defender TVM on GCC High)

• **Prioritize by exposure, not count.** Close the few recommendations that drive most of the exposure score first; don't chase a long tail.

• **Close patch findings with the Update ring, config findings with baselines.** Don't remediate by hand what a policy should enforce — manual fixes drift back.

• **Govern exceptions strictly.** Every exception needs a justification, an owner approval (R10), and an expiry. Medical-device and vendor-locked software are legitimate but must be time-bound and reviewed.

• **Work around the two Gov-unavailable DVM functions. Report inaccuracy** and **Request CVE support **do not exist in Gov — capture any recommendation-accuracy concern or CVE-coverage gap in your** own** change record (R12) and escalate through Microsoft support, rather than expecting the portal button.

- **Watch clinical/medical devices.** Many run unpatchable embedded OSes; isolate or compensate (network

segmentation) rather than silently accepting risk on the general baseline.

Evidence and audit readiness

- **Automate evidence on a cadence.** Schedule `HIPAACOMPG-Report.ps1` and

`HIPAACOMPG-Validation.ps1` (both `-Environment USGov`); date-stamp output.

- **Retain for the look-back period.** HIPAA documentation retention is six years; keep dated exports in

the sovereign, access-controlled repository.

- **Never put ePHI in evidence.** Reports capture device/compliance/exposure metadata only (GR6). The

evidence store must not become a new breach surface.

- **Keep baseline vs current exposure** to demonstrate trend over the period — assessors value trend over

a single snapshot. Note in your evidence where a Gov Secure Score recommendation differs from Commercial (an expected parity gap, not a finding).

Operations and change control

- **Pilot before broad rollout.** Apply new/changed objects to a small pilot subset of `HIPAA – Clinical

Endpoints` first, validate with the scripts, then expand in waves.

- **Gate changes through the owner.** Changes to compliance settings, the CA gate, and exceptions go

through the change/exception process (R12) with approval and a record.

- **Reconcile baseline conflicts.** If you apply a Microsoft Security baseline alongside targeted

baselines, resolve conflicts (Intune flags them in per-setting status); confirm the baseline version is present on your GCC High tenant first.

- **Use Microsoft Purview Compliance Manager** (`compliance.microsoft.us`) as an optional aid to track

improvement actions against a HIPAA/HITRUST template — treat its score as guidance, not certification, and confirm the template is available in your Gov tenant.

Least privilege and identity hygiene

- **Scope admin roles** (Intune Administrator, Security Administrator, Conditional Access Administrator)

in `entra.microsoft.us` rather than Global Administrator; make privileged roles PIM-eligible where licensed.

- **Enforce MFA for all admins** (and ideally all users) via `login.microsoftonline.us` — credential

theft remains the leading healthcare breach cause.

8. Deliverables Summary — HIPAA & HITRUST Endpoint Compliance & Vulnerability Remediation (Intune + Defender) — Government (GCC High)

This solution ships as a documentation set plus a script toolkit, authored for the **US sovereign cloud (GCC High)**. Together they let an administrator map the controls, build and gate the enforcement, remediate vulnerabilities, and produce audit-ready evidence on clinical Windows endpoints — using the `.us` **portals**, **US Gov service endpoints**, and **US Gov Microsoft Graph**.

> *The deliverables provide **technical enforcement and evidence** on a sovereign tenant. They do not constitute HIPAA compliance or HITRUST certification — those require organizational policy, risk analysis, training, BAAs, physical safeguards, and authorized assessment.*

Documentation

#	Document	Purpose
1	**Solution Overview** (`01-solution-overview.md`)	What the solution does on GCC High, scope, outcomes, the portal table, and the **Commercial vs GCC High — what's different** section.
2	**Requirements** (`02-requirements.md`)	Solution-specific prerequisites R1–R12 tuned for GCC High (US Gov licensing, Defender-for-GCC-High onboarding, Entra ID P1, BitLocker hardware, the `HIPAA – Clinical Endpoints` group, evidence store, change control) with verify/implement steps on the `.us` portals.
3	**Global Requirements — Healthcare Solutions** (`global-requirements-healthcare-solutions.md`)	Category-wide tenant/identity/network/data-handling baseline (GR1–GR9), applied on the sovereign portals.
4	**Implementation** (`03-implementation.md`)	Phase-by-phase build (Assess → Configure → Gate → Remediate → Evidence → Operate) with full `.us` navigation paths, named objects, and GCC-High caveats inline where they matter.
5	**Testing & Validation** (`05-testing.md`)	Gates 0–6 (on GCC High cloud, Compliant, CA blocks, safeguards enforced, exposure reduced, evidence produced) with expected results and evidence.

#	Document	Purpose
6	**Best Practices** (`07-best-practices.md`)	Operating guidance for a sovereign tenant: `.us` hygiene, naming/traceability, policy design, CA rollout, TVM, evidence, change control.
7	**Troubleshooting** (`06-troubleshooting.md`)	Common failure modes and fixes, including a dedicated **GCC High wrong-cloud / endpoint** section.
8	**Executive Summary** (`executive-summary.md`)	Business-level summary for decision-makers.
9	**GCC High Parity Notes** (`gcc-high-parity-notes.md`)	The **cited** Commercial-vs-GCC High/DoD parity reference — portals, API/Graph URIs, licensing, connectivity, and the Intune + Defender feature gaps that change the design.

Scripts (PowerShell, Microsoft Graph — US Gov `-Environment USGov`)

All scripts use the `HIPAACOMPG-` prefix, carry the standard header block, connect to **US Gov Graph** (`graph.microsoft.us`), and default to read-only. Change scripts default to `-WhatIf`.

#	Script	What it does
1	`HIPAACOMPG-Discovery.ps1`	Tenant readiness on GCC High: confirms the session is on **USGov**, then the named compliance policy + configuration baselines, Defender onboarding readiness, the CA gate, and BitLocker state. Read-only.
2	`HIPAACOMPG-Validation.ps1`	Per-device validation: compliant, encrypted, key safeguards present. Emits **PASS/FAIL**. Read-only.
3	`HIPAACOMPG-Report.ps1`	Consolidated audit evidence (compliance state + exposure context + safeguard status) to **CSV** for the sovereign evidence repository. Read-only.

#	Script	What it does
4	`HIPAACOMPG-Remediation.ps1`	Safe remediation: assigns `HIPAA – Clinical Endpoints` to any policy missing it. Defaults to `-WhatIf`; applies only with `-WhatIf:$false -Confirm:$false`.
5	`HIPAACOMPG-Set-ScopeTargeting.ps1`	Creates/ensures the `HIPAA – Clinical Endpoints` scope group and applies an Intune **scope tag** to the named policies. Defaults to `-WhatIf`.

Visual asset

- `HIPAACOMPG-hero.png` — hero image for the solution listing.

How the deliverables fit together

1. Read the **Requirements**, **Global Requirements**, and **GCC High Parity Notes**; close gaps on the `.us` portals.
1. Run `HIPAACOMPG-Discovery.ps1` to confirm you are on **USGov** and baseline tenant readiness.
2. Follow the **Implementation** to build the named compliance policy, configuration baselines (BitLocker, lock, AV, firewall, Update ring, access), and the CA gate; then run the Defender TVM remediation workflow. Use `HIPAACOMPG-Set-ScopeTargeting.ps1` to ensure the scope group and scope tags.
1. Validate with the **Testing** gates using `HIPAACOMPG-Validation.ps1`.
2. Produce evidence with `HIPAACOMPG-Report.ps1`; remediate drift with `HIPAACOMPG-Remediation.ps1` (`-WhatIf` then apply).
1. Operate continuously per **Best Practices**, using **Troubleshooting** as needed.

Appendix A — PowerShell Scripts

Included in the accompanying ZIP. Each script's header documents full usage.

HIPAACOMPG-Discovery.ps1

Purpose: Confirms the PowerShell session is on the US Government cloud (USGov), then inventories the named HIPAA/HITRUST objects on your GCC High tenant: the clinical scope group, the compliance policy, the BitLocker/lock/AV/firewall/access configuration baselines, the Update ring, and the Conditional Access gate. Read-only — makes no changes. Replace values like your-tenant-id only if you script -TenantId. Connects to Microsoft Graph US Gov (graph.microsoft.us). HOW TO RUN powershell -ExecutionPolicy Bypass -File .\HIPAACOMPG-Discovery.ps1 (Graph scopes: DeviceManagementConfiguration.Read.All, DeviceManagementManagedDevices.Read.All, Group.Read.All, Policy.Read.All; connects with -Environment USGov) EXPECTED RESULTS A banner showing Environment: USGov, then a present/missing line per named object and a managed-device count. PASS = Environment is USGov and the expected objects are found and assigned to 'HIPAA - Clinical Endpoints'. FAIL = a Commercial-authority error or empty result means the session did not reach the US Gov cloud — see 06-troubleshooting.md, section F. .NOTES White-label — the repeatable way. Read-only against Microsoft Graph US Gov endpoints. #>

How to run: powershell -ExecutionPolicy Bypass -File .\HIPAACOMPG-Discovery.ps1 (Graph scopes: DeviceManagementConfiguration.Read.All, DeviceManagementManagedDevices.Read.All, Group.Read.All, Policy.Read.All; connects with -Environment USGov) EXPECTED RESULTS A banner showing Environment: USGov, then a present/missing line per named object and a managed-device count. PASS = Environment is USGov and the expected objects are found and assigned to 'HIPAA - Clinical Endpoints'. FAIL = a Commercial-authority error or empty result means the session did not reach the US Gov cloud — see 06-troubleshooting.md, section F. .NOTES White-label — the repeatable way. Read-only against Microsoft Graph US Gov endpoints. #>

HIPAACOMPG-Remediation.ps1

Purpose: Change script that closes the most common gap discovery finds: the clinical scope group is not assigned to the compliance policy or a configuration baseline. It appends the group to each named object's assignments. Runs in preview (-WhatIf) by default and only changes assignments — it never edits a setting, onboards, or offboards a device. Replace values like your-group-name only if you override the defaults. Connects to Microsoft Graph US Gov (graph.microsoft.us). HOW TO RUN powershell -ExecutionPolicy Bypass -File .\HIPAACOMPG-Remediation.ps1 # preview (WhatIf) powershell -ExecutionPolicy Bypass -File .\HIPAACOMPG-Remediation.ps1 -WhatIf:$false -Confirm:$false # apply (Graph scopes: DeviceManagementConfiguration.ReadWrite.All, Group.Read.All; connects with -Environment USGov) EXPECTED RESULTS A list of planned assignment changes. In preview nothing is written. When applied, the group 'HIPAA - Clinical Endpoints' is added to each named object missing it. PASS = the planned/applied changes match what HIPAACOMPG-Discovery.ps1 reported missing. A Commercial-authority error means the session did not reach the US Gov cloud (aborts to avoid changing the wrong tenant) — see 06-troubleshooting.md, section F. .NOTES White-label — the repeatable way. Read-only against Microsoft Graph US Gov endpoints unless you explicitly apply changes. #>

How to run: powershell -ExecutionPolicy Bypass -File .\HIPAACOMPG-Remediation.ps1 # preview (WhatIf) powershell -ExecutionPolicy Bypass -File .\HIPAACOMPG-Remediation.ps1 -WhatIf:$false -Confirm:$false # apply (Graph scopes: DeviceManagementConfiguration.ReadWrite.All, Group.Read.All;

connects with -Environment USGov) EXPECTED RESULTS A list of planned assignment changes. In preview nothing is written. When applied, the group 'HIPAA - Clinical Endpoints' is added to each named object missing it. PASS = the planned/applied changes match what HIPAACOMPG-Discovery.ps1 reported missing. A Commercial-authority error means the session did not reach the US Gov cloud (aborts to avoid changing the wrong tenant) — see 06-troubleshooting.md, section F. .NOTES White-label — the repeatable way. Read-only against Microsoft Graph US Gov endpoints unless you explicitly apply changes. #>

HIPAACOMPG-Report.ps1

Purpose: Produces a consolidated, date-stamped evidence report for the HIPAA/HITRUST endpoint control set on GCC High: per-device Intune compliance state and key safeguard status, plus best-effort tenant exposure/Secure-Score context. Output is CSV for the sovereign evidence repository. Captures configuration/compliance metadata only — never ePHI. Makes no changes. Replace values like your-evidence-path only when you set -OutputCsv. Connects to Microsoft Graph US Gov (graph.microsoft.us). HOW TO RUN powershell -ExecutionPolicy Bypass -File .\HIPAACOMPG-Report.ps1 -OutputCsv .\HIPAACOMPG-Report.csv (Graph scopes: DeviceManagementManagedDevices.Read.All, DeviceManagementConfiguration.Read.All, Group.Read.All, SecurityEvents.Read.All; connects with -Environment USGov) EXPECTED RESULTS A CSV plus a small summary CSV written to the evidence path, and a console summary (Windows devices, Compliant, Encrypted, exposure note). PASS = files written with device rows. An empty result or a Commercial-authority error means the session did not reach the US Gov cloud — see 06-troubleshooting.md, section F. Some Secure Score recommendations are omitted in Gov (expected parity gap). .NOTES White-label — the repeatable way. Read-only against Microsoft Graph US Gov endpoints. #>

How to run: powershell -ExecutionPolicy Bypass -File .\HIPAACOMPG-Report.ps1 -OutputCsv .\HIPAACOMPG-Report.csv (Graph scopes: DeviceManagementManagedDevices.Read.All, DeviceManagementConfiguration.Read.All, Group.Read.All, SecurityEvents.Read.All; connects with -Environment USGov) EXPECTED RESULTS A CSV plus a small summary CSV written to the evidence path, and a console summary (Windows devices, Compliant, Encrypted, exposure note). PASS = files written with device rows. An empty result or a Commercial-authority error means the session did not reach the US Gov cloud — see 06-troubleshooting.md, section F. Some Secure Score recommendations are omitted in Gov (expected parity gap). .NOTES White-label — the repeatable way. Read-only against Microsoft Graph US Gov endpoints. #>

HIPAACOMPG-Set-ScopeTargeting.ps1

Purpose: Change script that (1) ensures the security group 'HIPAA - Clinical Endpoints' exists on your GCC High tenant, creating it if missing, and (2) applies an Intune RBAC scope tag to the named compliance policy and configuration baselines so regional or mission admins see only their own devices and policies. Runs in preview (-WhatIf) by default; only creates the group and sets scope tags — it never changes device state or policy settings. Replace values like your-scope-tag-name only if you set -ScopeTagName. Connects to Microsoft Graph US Gov (graph.microsoft.us). HOW TO RUN powershell -ExecutionPolicy Bypass -File .\HIPAACOMPG-Set-ScopeTargeting.ps1 # preview: ensure group only powershell -ExecutionPolicy Bypass -File .\HIPAACOMPG-Set-ScopeTargeting.ps1 -ScopeTagName "HIPAA-Region-East" -WhatIf:$false -Confirm:$false # apply (Graph scopes: Group.ReadWrite.All, DeviceManagementConfiguration.ReadWrite.All, DeviceManagementRBAC.Read.All; connects with -Environment USGov) EXPECTED RESULTS The group is confirmed/created and, if -ScopeTagName is

given, its id is added to each named policy's roleScopeTagIds. In preview nothing is written. PASS = the group exists and each policy lists the scope tag after applying. A Commercial-authority error means the session did not reach the US Gov cloud (aborts) — see 06-troubleshooting.md, section F. .NOTES White-label — the repeatable way. Read-only against Microsoft Graph US Gov endpoints unless you explicitly apply changes. #>

How to run: powershell -ExecutionPolicy Bypass -File .\HIPAACOMPG-Set-ScopeTargeting.ps1 # preview: ensure group only powershell -ExecutionPolicy Bypass -File .\HIPAACOMPG-Set-ScopeTargeting.ps1 -ScopeTagName "HIPAA-Region-East" -WhatIf:$false -Confirm:$false # apply (Graph scopes: Group.ReadWrite.All, DeviceManagementConfiguration.ReadWrite.All, DeviceManagementRBAC.Read.All; connects with -Environment USGov) EXPECTED RESULTS The group is confirmed/created and, if -ScopeTagName is given, its id is added to each named policy's roleScopeTagIds. In preview nothing is written. PASS = the group exists and each policy lists the scope tag after applying. A Commercial-authority error means the session did not reach the US Gov cloud (aborts) — see 06-troubleshooting.md, section F. .NOTES White-label — the repeatable way. Read-only against Microsoft Graph US Gov endpoints unless you explicitly apply changes. #>

HIPAACOMPG-Validation.ps1

Purpose: For each in-scope clinical Windows device, reports whether it is Compliant and whether the key safeguards are enforced (encryption, Defender-managed, compliance state). Emits PASS or FAIL per device so you can see exactly which endpoint has a real gap. Read-only — makes no changes. Replace values like your-group-name only if you override -GroupName. Connects to Microsoft Graph US Gov (graph.microsoft.us). HOW TO RUN powershell -ExecutionPolicy Bypass -File .\HIPAACOMPG-Validation.ps1 (Graph scopes: DeviceManagementManagedDevices.Read.All, DeviceManagementConfiguration.Read.All, Group.Read.All; connects with -Environment USGov) EXPECTED RESULTS A per-device table with an overall PASS/FAIL and a summary. PASS = the device is Compliant and encrypted; FAIL identifies the failing safeguard to remediate. An empty result or a Commercial-authority error means the session did not reach the US Gov cloud — see 06-troubleshooting.md, section F. .NOTES White-label — the repeatable way. Read-only against Microsoft Graph US Gov endpoints. #>

How to run: powershell -ExecutionPolicy Bypass -File .\HIPAACOMPG-Validation.ps1 (Graph scopes: DeviceManagementManagedDevices.Read.All, DeviceManagementConfiguration.Read.All, Group.Read.All; connects with -Environment USGov) EXPECTED RESULTS A per-device table with an overall PASS/FAIL and a summary. PASS = the device is Compliant and encrypted; FAIL identifies the failing safeguard to remediate. An empty result or a Commercial-authority error means the session did not reach the US Gov cloud — see 06-troubleshooting.md, section F. .NOTES White-label — the repeatable way. Read-only against Microsoft Graph US Gov endpoints. #>